Seguridad y respaldos

Entrega 8 · Sistema de registro y gestión del Mundial de Fútbol · 8 de noviembre de 2026

Alcance

La base MundialFutbol contiene datos personales de jugadores, integrantes de cuerpos técnicos y árbitros. Se cifra en reposo con TDE AES-256 y se limita el acceso por roles. El TP4 toma como plataforma SQL Server 2022 Standard sobre Windows Server 2022; TDE no está disponible en Express.

TDE cifra archivos de datos, registro de transacciones y backups. No reemplaza la autorización ni cifra conexiones: una persona autorizada puede ver los datos en texto claro. Las conexiones cifradas y el firewall se configuran en la instancia y el sistema operativo.

Roles y permisos

Los cambios se exponen mediante SP y las consultas mediante Reportes. Ningún rol de aplicación recibe permisos directos sobre tablas de negocio; tampoco es sysadmin ni db_owner.

Rol	Puede	No puede
rol_AdministradorOperativo	Ejecutar SP de negocio y reportes; leer reportes.	Acceder a tablas directamente o administrar el servidor. Los loaders con lectura de rutas quedan reservados a DBA.
rol_CargadorResultados	Iniciar/finalizar partidos y registrar formaciones, cambios, goles y amonestaciones por SP.	Gestionar publicidad, ejecutar reportes o acceder directamente a tablas.
rol_GestorPublicidad	Gestionar publicidad y consultar ocupación e ingresos publicitarios.	Consultar reportes deportivos o modificar tablas directamente.
rol_ConsultaReportes	Leer vistas y ejecutar SP del esquema Reportes.	Ejecutar operaciones de negocio o modificar datos.

Los usuarios usr_test_* son principals WITHOUT LOGIN para pruebas. En producción, el DBA mapea identidades reales a cada rol. Los loaders con BULK INSERT u OPENROWSET(BULK) requieren ADMINISTER BULK OPERATIONS, permiso de servidor no concedido a roles de aplicación.

Cifrado en reposo con TDE

Preparación del certificado

Realizar una vez por instancia como sysadmin, antes de crear el DEK. El certificado vive en master y debe respaldarse antes de crear la clave de cifrado de la base. Guardar certificado, clave privada y contraseña fuera del servidor; nunca subirlos al repositorio.

Si la clave maestra o certificado ya existen, no recrearlos: verificar la huella y exportar la clave privada si falta el backup. Perder el certificado o su clave privada puede volver irrecuperables los backups cifrados.

Ejemplo de aprovisionamiento (reemplazar los placeholders en una sesión privada):

```
USE master;
GO
CREATE MASTER KEY ENCRYPTION BY PASSWORD = N'<contraseña robusta>';
GO
CREATE CERTIFICATE CertMundialFutbolTDE
  WITH SUBJECT = N'Cifrado TDE de MundialFutbol';
GO
BACKUP CERTIFICATE CertMundialFutbolTDE
  TO FILE = N'<ruta segura>\CertMundialFutbolTDE.cer'
  WITH PRIVATE KEY (
    FILE = N'<ruta segura>\CertMundialFutbolTDE.pvk',
    ENCRYPTION BY PASSWORD = N'<contraseña robusta distinta>'
  );
GO
```

Activación y validación

Con el certificado respaldado, 41_Activar_CifradoTDE.sql crea el DEK AES-256 y activa TDE. El cifrado se completa en segundo plano: esperar encryption_state = 3 y ejecutar 85_Test_CifradoTDE.sql, que comprueba algoritmo, longitud y huella del certificado.

La activación requiere SQL Server 2022 Standard o Enterprise y sysadmin. Al restaurar una base protegida, importar primero en master el certificado y su clave privada respaldados.

Política de respaldos

El objetivo de punto de recuperación (RPO) se ajusta al volumen de escrituras. La base usa recuperación FULL; los backups del log deben ejecutarse regularmente para sostener la cadena y el RPO.

Situación	Completo	Diferencial	Log	RPO máximo
Días con partidos	Diario, 01:00	Cada 6 horas	Cada 5 minutos	5 minutos
Días sin partidos	Diario, 01:00	Cada 12 horas	Cada 15 minutos	15 minutos

Controles operativos

• Almacenar en volumen distinto de los MDF/LDF y copiar a segundo medio y ubicación fuera del servidor (regla 3-2-1); restringir acceso a operadores de backup.

• Usar COMPRESSION y CHECKSUM; comprobar con RESTORE VERIFYONLY; ejecutar DBCC CHECKDB semanalmente y restaurar una copia aislada al menos mensualmente para medir el RTO.

• Retener completos, diferenciales y logs 35 días. Conservar las cadenas necesarias para restaurar cualquier punto dentro de ese plazo.

• Para recuperar: último completo con NORECOVERY, diferencial más reciente con NORECOVERY y logs en orden; usar STOPAT si corresponde y terminar con RECOVERY.

Pruebas incluidas

Ejecutar 81_Test_Rol_Administrador.sql, 82_Test_Rol_CargadorResultados.sql, 83_Test_Rol_GestorPublicidad.sql y 84_Test_Rol_ConsultaReportes.sql después de 40_Seguridad.sql. 85_Test_CifradoTDE.sql valida el cifrado completo con AES-256 y el certificado esperado.